UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

Ingeniería de Software

Requisitos y mecanismos de seguridad

Aplicación de salas de chat seguras

Laboratorio 3

Asignatura: Desarrollo de Software Seguro

Docente: Angel Cudco

NRC: 36900

Integrantes

Jeancarlo Santi
Josue Solano
Alexander Toapanta

Sangolquí, Ecuador
15 de octubre de 2026

Contenido

Introducción y decisiones de alcance **1**

1 Actividad 1. Requisitos funcionales **1**

2 Actividad 2. Requisitos no funcionales **3**

3 Actividad 3. Requisitos de seguridad **4**

4 Actividad 4. Propiedades de seguridad **6**

5 Actividad 5. Técnicas y mecanismos seleccionados **7**

6 Actividad 6. Enfoques de desarrollo seguro y normas **9**

7 Actividad 7. Matriz de trazabilidad **10**

Conclusiones **11**

Referencias **12**

Índice de tablas

1 Requisitos funcionales 1
2 Requisitos no funcionales y aceptación 3
3 Requisitos de seguridad y su verificación 4
4 Propiedades y relación con los requisitos 6
5 Técnicas, mecanismos y justificación 7
6 Aplicación de los tres enfoques 9
7 Vinculación normativa con el proyecto 9
8 Trazabilidad de los quince activos y riesgos 10

Introducción y decisiones de alcance

Este laboratorio transforma el análisis de los quince activos y riesgos en requisitos que orientarán el desarrollo de la aplicación. Conservamos los identificadores A01–A15 y R01–R15 del trabajo anterior para relacionar cada protección con el problema que busca resolver. Se especifican los servicios del chat, las condiciones de calidad, los requisitos de seguridad y sus formas de verificación.

La aplicación permitirá administrar salas con identificador, clave, aforo y modalidad de texto, multimedia o ambos. Los participantes podrán intercambiar mensajes y archivos únicamente dentro de las salas autorizadas. El servidor comprobará permisos y sesiones, y los archivos pasarán por revisión antes de estar disponibles.

Identidad y sesión única. Se decidió asociar cada participante con una cuenta de identificador estable y credenciales propias. Esta decisión permite reconocer al mismo usuario en diferentes entornos. Para ingresar a una sala se exigirá, además, su identificador y clave. Habrá una sola sesión autenticada y una sola conexión de chat activa por identidad en toda la aplicación; una segunda conexión se rechazará sin expulsar a la primera. La restricción se verificará también desde otras pestañas y máquinas virtuales. No se utilizará la dirección IP como identidad ni se afirmará identificar de forma infalible un equipo físico.

Archivos. Para concretar la primera implementación se seleccionaron imágenes PNG y JPEG, hasta 5 MiB y 20 megapíxeles. Se mantendrán las modalidades de texto y multimedia; incorporar audio, video u otros formatos requerirá ampliar su validación y análisis. Los resultados de revisión serán: permitido, rechazado o inconcluso. Solo el primero habilitará la descarga por participantes autorizados.

Criterios de aceptación. Son condiciones que permitirán decidir si un requisito se cumple. Pueden expresarse con texto o fórmulas, pero siempre describen un resultado observable. Las cifras de rendimiento y capacidad son metas de diseño del equipo para las pruebas, no resultados obtenidos.

Riesgo residual. Conforme a la indicación de clase, se evaluará después del desarrollo. En esta entrega se define la trazabilidad y la comprobación de los controles; no se recalculan ni se presentan como comprobados los valores residuales estimados anteriormente.

1 Actividad 1. Requisitos funcionales

Los requisitos funcionales indican qué servicios ofrecerá el sistema. Se usa prioridad alta para funciones esenciales de acceso, comunicación y protección; media para funciones de gestión que complementan la operación. “Sistema” identifica un comportamiento automático, no una persona externa.

Tabla 1: Requisitos funcionales

Código	Requisito	Descripción	Actor	Prioridad
RF-01	Acceso administrativo	Permitir al administrador iniciar sesión con credenciales válidas y segunda verificación.	Administrador	Alta
RF-02	Identidad del participante	Permitir que el participante inicie sesión con su cuenta e identificador estable.	Participante	Alta
RF-03	Creación de salas	Crear salas con identificador único, clave, aforo y modalidad: texto, multimedia o ambos.	Administrador	Alta
RF-04	Consulta y modificación	Consultar salas y modificar su clave y modalidad; el nuevo aforo no podrá ser menor que la ocupación actual.	Administrador	Media
RF-05	Cierre de salas	Cerrar una sala, desconectar a sus participantes e impedir nuevos ingresos y envíos.	Administrador	Alta

Continúa en la página siguiente

Requisitos funcionales (continuación)

Código	**Requisito**	**Descripción**	**Actor**	**Prioridad**
RF-06	Ingreso a salas	Ingresar mediante identificador y clave de sala, después de autenticar al participante; rechazar datos inválidos o salas cerradas.	Participante	Alta
RF-07	Control de aforo	Mostrar la ocupación y rechazar nuevos ingresos cuando se alcance el máximo; resolver ingresos simultáneos sin excederlo.	Sistema	Alta
RF-08	Conexión única	Rechazar una segunda sesión o conexión de chat de la misma identidad, incluso desde otra pestaña, navegador, equipo o máquina virtual.	Sistema	Alta
RF-09	Salida y fin de sesión	Permitir salir de una sala o cerrar sesión; al cerrar sesión invalidar el acceso y liberar su conexión.	Participante y administrador	Alta
RF-10	Mensajes de texto	Enviar y recibir texto en tiempo real con remitente reconocido por el servidor, dentro de la sala y modalidad autorizadas.	Participante	Alta
RF-11	Intercambio de imágenes	Cargar imágenes y descargar solo las permitidas, dentro de la sala y modalidad autorizadas.	Participante	Alta
RF-12	Revisión previa	Comprobar formato real, tamaño, dimensiones y contenido peligroso antes de habilitar una imagen.	Sistema	Alta
RF-13	Análisis esteganográfico	Analizar indicios de información oculta y clasificar el archivo como permitido, rechazado o inconcluso.	Sistema	Alta
RF-14	Alertas y cuarentena	Retener archivos sospechosos o inconclusos, informar al remitente del estado y alertar al administrador.	Sistema	Alta
RF-15	Consulta de auditoría	Registrar accesos, rechazos, cambios de sala, sesiones y decisiones sobre archivos; permitir su consulta al administrador autorizado.	Administrador y sistema	Media

2 Actividad 2. Requisitos no funcionales

Estos requisitos describen cómo debe funcionar la aplicación. Para comparar los resultados, las pruebas de carga usarán un entorno registrado con al menos 4 núcleos lógicos, 8 GiB de RAM y una red local controlada. Se documentarán versiones y recursos asignados; los tiempos se medirán con relojes sincronizados. Esta referencia permite repetir las pruebas.

Tabla 2: Requisitos no funcionales y aceptación

Código	Atributo	Requisito	Criterio de aceptación
RNF-01	Rendimiento del chat	Entregar mensajes con baja demora.	Con 50 participantes en 5 salas, cada uno enviando un mensaje de hasta 1 KiB cada 5 s durante 10 min: al menos 95% de las entregas en 2 s o menos, desde aceptación del servidor hasta recepción.
RNF-02	Rendimiento multimedia	Analizar imágenes sin bloquear los mensajes.	Con 5 análisis simultáneos de imágenes dentro de los límites: al menos 95% termina en 10 s o menos y se mantiene RNF-01. Un análisis que exceda 15 s queda inconcluso y sin publicar.
RNF-03	Disponibilidad	Mantener operativas las funciones de acceso y chat.	En 8 h de prueba continua, sondas de ingreso y envío cada minuto: disponibilidad de al menos 99%. Cálculo: 100× sondas satisfactorias / sondas programadas; una sonda omitida cuenta como fallo.
RNF-04	Escalabilidad	Atender un aumento de usuarios sin romper los controles.	Pasar de 50 a 100 participantes en 10 salas, con el patrón de RNF-01 por 10 min: al menos 95% de entregas en 3 s o menos, sin exceder aforos ni permitir conexiones duplicadas. Registrar consumo y configuración.
RNF-05	Usabilidad	Presentar acciones y errores comprensibles.	Al menos 4 de 5 usuarios de prueba ingresan a una sala, envían un mensaje y comparten una imagen permitida sin ayuda, en un máximo de 5 min; los rechazos explican la acción posible sin revelar secretos.
RNF-06	Mantenibilidad	Separar acceso, chat y análisis para facilitar cambios.	Una modificación del detector no requiere cambiar el módulo de autenticación; se ejecutan las pruebas de ambos y pasan. Se conservan instrucciones reproducibles de instalación y prueba.
RNF-07	Interoperabilidad	Ofrecer el mismo comportamiento en navegadores y sistemas diferentes.	Ingreso, texto, imagen y salida funcionan en versiones estables registradas de Chrome, Firefox y Brave, tanto en Windows como en Ubuntu, sin fallos en los casos definidos.
RNF-08	Confiabilidad	Mantener consistencia ante desconexiones y reintentos.	En 100 reintentos controlados, ningún mensaje con el mismo identificador se muestra dos veces. Al perder la conexión, se informa al usuario y no se confirma como entregado un mensaje pendiente.
RNF-09	Recuperación	Restablecer configuración, membresías, archivos vigentes y registros persistidos.	Restaurar una copia en entorno limpio en un máximo de 2 h, con pérdida máxima de 24 h de esos datos; verificar su integridad. Los mensajes del chat en vivo no se almacenan ni se reconstruyen.
RNF-10	Monitoreo	Permitir detectar errores y actividad sospechosa.	Cada uno de los eventos de RF-15 generados en prueba aparece con hora, identidad, sala cuando corresponda y resultado. Una alerta de archivo sospechoso llega a la consola administrativa en 5 s o menos.

3 Actividad 3. Requisitos de seguridad

Se relacionó cada uno de los quince escenarios con un requisito principal y se añadió uno transversal para el desarrollo seguro. La columna de verificación define qué resultado se comprobará al implementar. Las medidas de acceso, sesiones y revisión de archivos se apoyan en las guías de OWASP [3, 4, 5].

Tabla 3: Requisitos de seguridad y su verificación

Código	**Requisito de seguridad**	**Activo / riesgo**	**Verificación esperada**
RS-01	Exigir contraseña fuerte, MFA administrativo y limitación de intentos; almacenar contraseñas con hash adaptativo y sal individual.	A01 / R01	Contraseña incorrecta o segundo factor ausente se rechazan. Tras 5 fallos en 15 min por cuenta se aplica espera de 15 min. En base de datos no hay contraseñas legibles.
RS-02	Generar claves de sala aleatorias de al menos 128 bits; guardar su hash y limitar los intentos de ingreso.	A02 / R02	Clave errónea o anterior tras rotación: acceso denegado. Tras 5 fallos por identidad y sala en 15 min se aplica espera de 15 min; verificar la fuente aleatoria.
RS-03	Mantener una sola sesión y conexión de chat por identidad mediante registro central y reserva atómica; liberar conexiones interrumpidas sin admitir dos a la vez.	A03 / R03	En 100 pares de intentos simultáneos, solo uno queda activo. Repetir desde pestañas, navegadores, equipos y VM, con sesión compartida y con nuevo inicio. Tras pérdida de conexión, liberar en 60 s como máximo.
RS-04	Usar identificadores de sesión impredecibles; protegerlos en cookies Secure, HttpOnly y SameSite; rotarlos al autenticar, revocarlos al salir y vencer tras 15 min de inactividad.	A04 / R04	Sesión anterior al acceso, vencida o cerrada: operación denegada y socket cerrado. Comprobar que no aparece en URL ni registros; tráfico de heartbeat no renueva la inactividad del usuario.
RS-05	Denegar por defecto y comprobar rol, pertenencia, aforo y modalidad en servidor en cada acción; validar origen WebSocket y proteger operaciones HTTP frente a CSRF.	A05 / R05	Participante no modifica ni cierra salas; identidad ajena no lee ni descarga. Solicitudes de origen no autorizado y operaciones HTTP sin protección CSRF se rechazan. Un cambio de modalidad se aplica a los siguientes envíos.
RS-06	Exigir HTTPS y WSS con TLS 1.3 y certificados válidos para mensajes, credenciales y archivos.	A06 / R06	Captura de red sin contenido legible; conexión WebSocket sin cifrar denegada, certificado inválido rechazado y negociación TLS verificada.
RS-07	Asignar remitente desde la sesión y comprobar sala e identificador único del mensaje antes de distribuirlo.	A07 / R07	Cambiar el remitente enviado no permite suplantar a otro; repetir un identificador no duplica el mensaje. Un usuario ajeno no puede publicar en la sala.
RS-08	Validar estructura y longitud en servidor y mostrar mensajes como texto, sin ejecutar HTML ni scripts.	A08 / R08	Mensajes con etiquetas, eventos HTML o scripts se muestran como texto o se rechazan; no ejecutan código. Estructuras inválidas y texto mayor de 4 KiB se rechazan.
RS-09	Mantener claves criptográficas fuera del código y registros, con acceso mínimo, separación por función y procedimiento de rotación. Cifrar archivos persistidos con cifrado autenticado.	A09 / R09	Escaneo del repositorio sin secretos; cuenta no autorizada no obtiene claves. Rotar una clave de prueba, conservar acceso autorizado a datos vigentes y comprobar que una alteración del archivo cifrado se detecta.

Continúa en la página siguiente

Requisitos de seguridad y su verificación (continuación)

Código	**Requisito de seguridad**	**Activo / riesgo**	**Verificación esperada**
RS-10	Usar consultas parametrizadas y una cuenta de base de datos con permisos limitados a las operaciones necesarias.	A10 / R10	Entradas de prueba SQL no alteran la consulta ni dan acceso adicional. Revisar consultas y comprobar que la cuenta no puede administrar el motor.
RS-11	Validar formato real, tamaño, dimensiones y contenido de las imágenes; mantenerlas privadas hasta completar todas las revisiones y autorizar cada descarga.	A11 / R11	Rechazar extensiones falsas, imágenes dañadas, archivos mayores de 5 MiB o de 20 megapíxeles. Un archivo pendiente no es descargable ni por enlace directo; uno permitido tampoco por una identidad ajena.
RS-12	Ejecutar el analizador aislado, actualizado y sin privilegios, con límite de 2 GiB de memoria y 15 s por tarea, sin acceso a claves o base del chat.	A12 / R12	Un archivo preparado para bloquear el analizador termina sin caída del chat; el proceso no puede leer secretos ni consultar la base. Al fallar, el archivo no se publica.
RS-13	Aplicar esteganálisis con técnicas declaradas, retener sospechosos e inconclusos y asociar la decisión con los mismos bytes que se compartirán.	A13 / R13	Pruebas con imágenes limpias y alteradas; medir detección y falsos positivos. Reemplazar los bytes invalida el resultado previo. Fallo o resultado inconcluso impiden la publicación.
RS-14	Limitar envíos a 5 mensajes/s y 2 cargas/min por identidad; controlar además IP y capacidad global, y separar la cola de análisis del chat.	A14 / R14	El sexto mensaje en un segundo y la tercera carga en un minuto se rechazan sin desconectar usuarios legítimos. Con 50 usuarios legítimos y 10 de abuso, mantener RNF-01; probar recuperación RNF-09.
RS-15	Enviar auditoría a un destino separado con permiso de inserción, restringir lectura y borrado, generar alertas y excluir claves, sesiones y texto privado.	A15 / R15	La cuenta del chat inserta pero no modifica ni borra eventos recibidos. Se registran los casos de RF-15 y se alerta según RNF-10. Revisar ausencia de secretos; borrar archivos al cumplirse 24 h del cierre y logs a los 30 días.
RS-16	Revisar cambios por otro integrante y ejecutar análisis de código, dependencias, secretos y pruebas de seguridad antes de integrar o entregar.	Transversal	Conservar revisión, reportes SAST/SCA y secretos por cambio; DAST y pruebas de acceso, sesión y archivos por entrega. No quedan hallazgos técnicos críticos confirmados sin corregir.

Lectura de la relación. RS-03 trata R03, pero también depende de una identidad autenticada. RS-11 revisa archivos peligrosos y RS-13 busca información oculta: son controles distintos, aunque ambos deben terminar antes de compartir. RS-16 apoya a todos los controles al detectar errores durante el desarrollo.

4 Actividad 4. Propiedades de seguridad

Se consideraron las once propiedades solicitadas. CID protege información y servicio; AAA organiza identidad, permisos y registro de acciones. Las propiedades complementarias precisan otros resultados necesarios para el chat.

Tabla 4: Propiedades y relación con los requisitos

Grupo	**Propiedad**	**Aplicación en el sistema**	**Amenaza**	**Requisito**
CID	Confidencialidad	Solo miembros autorizados leen mensajes y archivos; credenciales y claves permanecen protegidas.	Interceptación o acceso ajeno.	RS-02, 05, 06, 09, 11
CID	Integridad	Mensajes, configuración, archivos y decisiones de análisis no se alteran sin autorización.	Manipulación, SQLi o cambio del archivo revisado.	RS-05, 07, 09, 10, 13
CID	Disponibilidad	El chat conserva recursos y puede recuperarse de una interrupción.	Saturación o fallo del analizador.	RS-12, 14; RNF-09
AAA	Autenticación	Comprobar la identidad propia del participante y del administrador antes del acceso.	Contraseñas robadas o sesión reutilizada.	RS-01, 03, 04
AAA	Autorización	Verificar quién puede administrar, ingresar, enviar y descargar en cada sala.	Escalada de permisos o acceso entre salas.	RS-02, 05, 11
AAA	Auditoría / contabilización	Registrar qué identidad realizó una acción, cuándo y con qué resultado.	Acciones indebidas que pasan inadvertidas.	RS-15
Complementaria	Autenticidad	Asegurar que el remitente mostrado corresponde a la sesión y que el servidor es el esperado.	Remitente falso o servidor suplantado.	RS-06, 07
Complementaria	No repudio	Conservar evidencia de acciones administrativas atribuida a una cuenta, con hora y protección frente a cambios.	Negación de un cambio o borrado de evidencia.	RS-01, 15
Complementaria	Trazabilidad	Relacionar acceso, acción, sala y decisión sobre archivos mediante identificadores de evento.	Ocultamiento de la secuencia de un incidente.	RS-07, 13, 15
Complementaria	Privacidad	Evitar datos personales y contenido privado innecesarios en registros; limitar acceso y conservación.	Exposición de conversaciones o conservación excesiva.	RS-04, 11, 15
Complementaria	Resiliencia	Contener un fallo del análisis, mantener el chat y recuperar datos persistidos.	Archivo que bloquea tareas o caída del servidor.	RS-12, 14; RNF-09

Alcance del no repudio. Los registros protegidos aportan evidencia técnica de lo realizado por una cuenta, pero no demuestran por sí solos quién estaba físicamente frente al equipo. Para un no repudio fuerte se necesitarían firmas digitales y gestión de claves personales; no se atribuye esa garantía al registro de auditoría.

5 Actividad 5. Técnicas y mecanismos seleccionados

Se seleccionaron mecanismos concretos para llevar los requisitos al código y a la configuración. TLS protege el canal; los controles de sesión y permisos deben aplicarse además en el servidor. Las guías de OWASP orientan los mecanismos de acceso y archivos, y NIST orienta su incorporación al desarrollo [3, 4, 5, 7].

Tabla 5: Técnicas, mecanismos y justificación

ID	Técnica	Mecanismo	Requisito	Justificación	Riesgo
T01	Hash y segundo factor	Argon2id con sal individual y TOTP para el administrador; generador criptográfico para claves de sala.	RS-01, 02	Dificulta usar contraseñas filtradas o adivinar accesos; TOTP exige una segunda prueba de identidad.	R01, R02
T02	Sesión centralizada	Registro central con restricción única por identidad y transacción atómica; heartbeat y revocación.	RS-03, 04	Impide que dos solicitudes simultáneas eludan el control; libera conexiones perdidas.	R03, R04
T03	Autorización continua	Roles de administrador y participante, membresía por sala, denegación por defecto, lista de orígenes y token CSRF.	RS-05	Evita acciones entre salas y solicitudes desde sitios ajenos, aunque se manipule la interfaz.	R05
T04	Canal cifrado	HTTPS/WSS con TLS 1.3 y certificados válidos.	RS-06	Protege confidencialidad e integridad durante el transporte.	R06
T05	Identidad del mensaje	Remitente obtenido de la sesión, identificador único y registro de deduplicación.	RS-07	Evita atribución falsa y repetición de un mismo envío.	R07
T06	Validación y salida segura	Esquema de mensajes en servidor y presentación con textContent o equivalente de escape automático.	RS-08	Evita que el texto se convierta en instrucciones ejecutables; errores sin detalles internos.	R08
T07	Gestión de claves y cifrado	Secretos montados fuera del repositorio con permisos mínimos; AES-256-GCM para imágenes persistidas y rotación documentada.	RS-09	Protege claves y detecta alteración del contenido cifrado; separar claves limita su reutilización.	R09
T08	Consultas parametrizadas	Sentencias preparadas del controlador de base de datos y cuenta sin privilegios administrativos.	RS-10	Mantiene separados los datos y las instrucciones SQL.	R10
T09	Validación y cuarentena	Firma binaria y decodificación real, antivirus ClamAV, almacenamiento privado y descarga mediante autorización.	RS-11	Una extensión no basta para aceptar contenido; la cuarentena evita exposición antes de revisar.	R11
T10	Aislamiento de tareas	Trabajador en contenedor sin privilegios, límites de memoria y tiempo, sin secretos del chat ni red innecesaria.	RS-12	Contiene fallos y agotamiento de recursos del procesamiento.	R12
T11	Esteganálisis	Aletheia como herramienta candidata: detector para LSB replacement en PNG y detector JPEG para nsF5; decisión ligada al hash SHA-256 del archivo.	RS-13	Permite evaluar familias concretas de ocultamiento; no convierte un resultado negativo en garantía de limpieza.	R13

Continúa en la página siguiente

Técnicas, mecanismos y justificación (continuación)

ID	Técnica	Mecanismo	Requisito	Justificación	Riesgo
T12	Cuotas y recuperación	Limitador de tasa por identidad e IP, presupuesto global, cola multimedia separada y copias diarias cifradas.	RS-14; RNF-09	Contiene abuso y permite restaurar datos persistidos tras un fallo.	R14
T13	Auditoría protegida	Recolector separado con credencial de solo inserción para el chat, identificadores de correlación y alertas administrativas.	RS-15	Conserva evidencia fuera del proceso atacado y facilita responder a eventos.	R15
T14	Revisión y análisis temprano	Revisión por otro integrante, Semgrep (SAST), OSV-Scanner (SCA) y Gitleaks para secretos en la integración continua.	RS-16	Detecta patrones inseguros, dependencias vulnerables y secretos antes de integrar cambios.	Transversal
T15	Pruebas de seguridad	OWASP ZAP (DAST), cliente de pruebas WebSocket y pruebas automatizadas de permisos, concurrencia y archivos.	RS-03, 05, 11–16	Comprueba el comportamiento ejecutable, incluidos fallos que no se observan al leer el código.	Transversal

5.1 Pruebas de detección esteganográfica

Se evaluará por separado cada combinación de formato y técnica declarada. Se utilizarán al menos 100 imágenes limpias y 100 alteradas por combinación; las imágenes de evaluación serán distintas de las usadas para ajustar el detector; se conservarán fuera de las salas reales y no contendrán datos privados. Se registrará procedencia, técnica, carga oculta y versión de la herramienta. Aletheia ofrece algoritmos específicos y modelos que deben seleccionarse según el formato; su disponibilidad no demuestra su desempeño en nuestras muestras [8].

Detección. $100 \times D/N_a$, donde D son las imágenes alteradas correctamente marcadas como sospechosas y N_a todas las alteradas evaluadas. Meta: al menos 95% por combinación. Un resultado inconcluso no cuenta como detección correcta.

Falsos negativos. $100 \times FN/N_a$: imágenes alteradas que se clasifican como permitidas. **Falsos positivos.** $100 \times FP/N_l$: imágenes limpias marcadas como sospechosas, sobre todas las limpias evaluadas. Meta de falsos positivos: hasta 10%. Se informará además el porcentaje inconcluso de cada grupo, sin ocultarlo dentro de estas tasas.

Por ejemplo, 95 imágenes alteradas detectadas, 3 permitidas y 2 inconclusas, de 100, equivalen a 95% de detección, 3% de falsos negativos y 2% de inconclusos. Son cifras ilustrativas. La retención de un inconcluso evita publicarlo, pero no demuestra que se detectó la información oculta.

Cada análisis debe respetar RNF-02 y RS-12. Si no termina o el detector falla, se retiene el archivo y se genera una alerta. El resultado permitido solo se aplica a los bytes analizados; cambiar el archivo obliga a repetir la revisión. No se incorporarán técnicas o formatos nuevos sin sus pruebas correspondientes.

6 Actividad 6. Enfoques de desarrollo seguro y normas

6.1 Zero Trust, Secure by Design y Shift Left Security

Se decidió incorporar estos enfoques mediante prácticas observables: verificar cada acceso, diseñar las protecciones antes de programar y detectar fallos desde las primeras etapas. Zero Trust evita confiar en una solicitud solo por su ubicación o por mantener una conexión abierta; el desarrollo seguro integra prácticas de protección a lo largo del ciclo de vida [6, 7].

Tabla 6: Aplicación de los tres enfoques

Enfoque	**Práctica concreta**	**Fase**	**Evidencia prevista**
Zero Trust	Validar identidad, sesión y permiso de sala en cada envío, descarga y acción administrativa; aplicar mínimo privilegio entre componentes. RS-03–05, 11.	Diseño, implementación y pruebas	Pruebas de identidad ajena, sesión revocada y origen no permitido; matriz de roles.
Secure by Design	Separar chat, analizador y auditoría; diseñar canal cifrado y cuarentena antes de integrar la transferencia. RS-06, 09, 11–15.	Análisis y diseño	Diagrama de componentes, decisiones de acceso y pruebas de que un archivo pendiente no es descargable.
Shift Left Security	Revisar cambios y ejecutar análisis de código, dependencias y secretos desde los primeros cambios. RS-16.	Implementación e integración; pruebas por entrega	Revisión de otro integrante, reportes de análisis y resultados automatizados conservados con la versión.

6.2 Controles y prácticas normativas

Seleccionamos dos controles del Anexo A de ISO/IEC 27001:2022 y dos prácticas del proceso de ISO/IEC 27034. Se usan como orientación para el proyecto, con aplicación y evidencia específicas [1, 2]. En ISO/IEC 27034 se referencia el proceso de seguridad de aplicaciones; sus apartados no se presentan como controles del Anexo A.

Tabla 7: Vinculación normativa con el proyecto

Referencia	**Aplicación y justificación**	**Relación**	**Evidencia prevista**
ISO/IEC 27001:2022, A.8.24: uso de criptografía	Cifrar comunicaciones e imágenes persistidas y gestionar sus claves. Reduce exposición y alteración de información.	R06, R09; RS-06, 09	Configuración TLS, prueba de integridad del cifrado y procedimiento de rotación.
ISO/IEC 27001:2022, A.8.26: requisitos de seguridad de aplicaciones	Definir protecciones verificables antes de programar. Evita que acceso, sesiones y análisis se incorporen de manera incompleta.	R01–R15; RS-01–16	Matriz de requisitos, criterios de verificación y trazabilidad.
ISO/IEC 27034-3:2018, 6.1 y 6.2: requisitos, entorno y riesgos	Usar activos y riesgos del Laboratorio 2 para definir requisitos según el contexto real del chat.	A01–A15; R01–R15	Decisiones de alcance y relación de cada riesgo con su requisito.
ISO/IEC 27034-3:2018, 6.3 y 6.5: controles de aplicación y verificación	Mantener la selección de controles y comprobar su implementación mediante pruebas vinculadas a requisitos.	RS-01–16; T01–T15	Matriz de mecanismos y resultados de pruebas asociados a una versión del software.

7 Actividad 7. Matriz de trazabilidad

La matriz conserva los quince riesgos del informe anterior. Cada fila relaciona el activo, el requisito de seguridad, las propiedades principales y el mecanismo que contribuirá a su tratamiento. RS-16 y las técnicas T14–T15 son transversales a todas las filas. El riesgo residual se mantiene pendiente de la evaluación posterior al desarrollo.

Tabla 8: Trazabilidad de los quince activos y riesgos

Activo / riesgo	**Activo**	**Riesgo identificado**	**Requisito**	**Propiedades**	**Técnica o mecanismo**
A01 / R01	Credenciales administrativas	Acceso no autorizado a la administración	RS-01	Autenticación; autorización	T01: hash, MFA y límites de acceso.
A02 / R02	Claves de sala	Ingreso ajeno a una sala	RS-02, 05	Confidencialidad; autorización	T01 y T03: claves aleatorias, hash y permisos.
A03 / R03	Sesiones activas	Conexiones simultáneas	RS-03	Autenticación; integridad	T02: reserva única y atómica por identidad.
A04 / R04	Identificadores de sesión	Suplantación de sesión	RS-04	Autenticación; confidencialidad	T02: cookies protegidas, rotación, expiración y revocación.
A05 / R05	Configuración y permisos	Cambios sin permiso	RS-05	Autorización; integridad	T03: roles y validación de cada acción en servidor.
A06 / R06	Canal de comunicación	Interceptación de mensajes	RS-06	Confidencialidad; integridad; autenticidad	T04: HTTPS/WSS con TLS y certificado válido.
A07 / R07	Mensajes	Remitente falso o duplicados	RS-07	Integridad; autenticidad; trazabilidad	T05: identidad de sesión e identificadores de mensaje.
A08 / R08	Interfaz del chat	Código malicioso en mensajes	RS-08	Confidencialidad; integridad	T06: esquema de entrada y presentación como texto.
A09 / R09	Claves de cifrado	Robo de claves	RS-09	Confidencialidad; integridad	T07: secretos separados, permisos y cifrado autenticado.
A10 / R10	Base de datos	Inyección SQL	RS-10	Confidencialidad; integridad; disponibilidad	T08: consultas parametrizadas y cuenta limitada.
A11 / R11	Archivos compartidos	Archivo dañino distribuido	RS-11	Confidencialidad; integridad; privacidad	T09: validación, antivirus y descarga autorizada.
A12 / R12	Analizador de archivos	Fallo o explotación del analizador	RS-12	Disponibilidad; integridad; resiliencia	T10: trabajador aislado y recursos limitados.
A13 / R13	Resultados de esteganálisis	Contenido oculto no detectado	RS-13	Integridad; confidencialidad	T11 y T09: detector, decisión ligada al archivo y cuarentena.
A14 / R14	Servidor del chat	Saturación del chat	RS-14; RNF-09	Disponibilidad; resiliencia	T12: cuotas, cola separada y recuperación.
A15 / R15	Auditoría y alertas	Borrado de registros	RS-15	Auditoría; trazabilidad; privacidad; no repudio limitado	T13: destino separado, permisos y alertas.

7.1 Justificación del tratamiento y aspectos por completar

Los controles de identidad y permisos dificultan accesos indebidos; el cifrado protege el transporte; la validación y el aislamiento reducen la exposición a archivos peligrosos; las cuotas y la auditoría ayudan a contener y detectar incidentes. Esta relación explica la contribución de los mecanismos, sin asumir que su sola selección demuestra eficacia.

R01 y R09 conservan atención prioritaria por el alcance de una cuenta administrativa o una clave comprometida. Antes de su evaluación final se revisará si conviene separar administración de plataforma y de salas, y usar claves con alcance menor. R13 requiere validar el detector para cada técnica y formato; las muestras no reconocidas seguirán siendo una limitación. R14 requiere comprobar capacidad y valorar protección adicional frente a ataques distribuidos que superen la infraestructura disponible.

El control de sesión única de R03 se probará con una misma identidad en todos los entornos previstos. No impide que una persona utilice cuentas diferentes; resolver esa situación requeriría una política adicional de alta y verificación de usuarios. No repudio conserva el alcance técnico limitado explicado en la actividad 4.

Después del desarrollo se reunirán los resultados de verificación y se reevaluarán probabilidad e impacto del mismo escenario para calcular el riesgo residual. Hasta entonces, el estado de esa valoración es **pendiente de evaluación**, no cero ni riesgo eliminado.

Conclusiones

Se definieron quince requisitos funcionales, diez no funcionales y dieciséis de seguridad, vinculados con los quince activos y riesgos del análisis previo. La especificación permite distinguir qué hará el sistema, bajo qué condiciones de calidad y cómo se comprobarán sus protecciones.

Consideramos esencial resolver la identidad del participante, comprobar la sesión única en distintos entornos y evitar que los archivos se compartan antes de completar su revisión. Las propiedades, mecanismos y prácticas seleccionadas ofrecen una base concreta para comenzar el desarrollo y evaluar posteriormente el riesgo residual.

Referencias

[1] ISO/IEC. (2022). *ISO/IEC 27001:2022. Information security management systems – Requirements*. https://www.iso.org/standard/27001.

[2] ISO/IEC. (2018). *ISO/IEC 27034-3. Application security management process*, apartados 6.1–6.5. https://www.iso.org/standard/55583.html.

[3] OWASP Foundation. (s. f.). *WebSocket Security Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/WebSocket_Security_Cheat_Sheet.html.

[4] OWASP Foundation. (s. f.). *File Upload Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html.

[5] OWASP Foundation. (s. f.). *Password Storage Cheat Sheet*. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html.

[6] Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero Trust Architecture*. NIST SP 800-207. https://doi.org/10.6028/NIST.SP.800-207.

[7] Souppaya, M., Scarfone, K. y Dodson, D. (2022). *Secure Software Development Framework (SSDF), Version 1.1*. NIST SP 800-218. https://doi.org/10.6028/NIST.SP.800-218.

[8] Lerch-Hostalot, D. (s. f.). *Aletheia: Image Steganalysis*. Repositorio y documentación del proyecto. https://github.com/daniellerch/aletheia.